Module 5 Learner Guide: Incident Response and Integrated Capstone

Start here

This is the last module. You learn how an office responds when something goes wrong, then your team runs the RSSO's response to a fictional incident, round by round. Every person, office, address and record in this module is fictional.

Item	Detail
Face-to-face	Friday 23 October 2026, 8:00 AM to 12:00 NN
Graded	The capstone tabletop exercise, 40% of the course, as a team. Every member receives the team score after a participation check
Bring	Your desk card, your Module 4 findings register, and at least one laptop per team for the incident log and the report
Teams	Your Day 1 team. Roles are drawn by lot

What you will be able to do

Level	By noon you can	Where
Remember	Name the phases of incident response and the 72-5 rule	Lesson 5.1; the notification section
Understand	Explain who does what in each phase, and why evidence comes before repair	Lesson 5.1.1
Apply	Put first-hour actions in a safe order	Try it 5.1
Analyze	Decide whether an incident must be reported to the NPC, and when the clock started	Try it 5.2; the tabletop
Evaluate	Weigh pressure to deny or pay against the law and the evidence	The tabletop, Round 3
Create	An immediate response plan, an incident log and a final incident report	The tabletop and the report

This morning

Time	Minutes	Segment
8:00 to 8:10	10	Recall and capstone briefing
8:10 to 8:55	45	5.1 The incident response plan; 5.1.1 roles; duties when personal data is involved
8:55 to 9:05	10	Break
9:05 to 9:20	15	Tabletop briefing
9:20 to 10:40	80	Tabletop exercise: three rounds (graded)
10:40 to 10:50	10	Break
10:50 to 11:15	25	Final incident report
11:15 to 11:40	25	Team report-outs and hot wash
11:40 to 12:00	20	Course close

Lesson 5.1: Creating an incident response plan

Key idea: decide before anything happens who does what, in what order, and who must be told. A plan written during the incident is written too late.

Event, incident or breach?

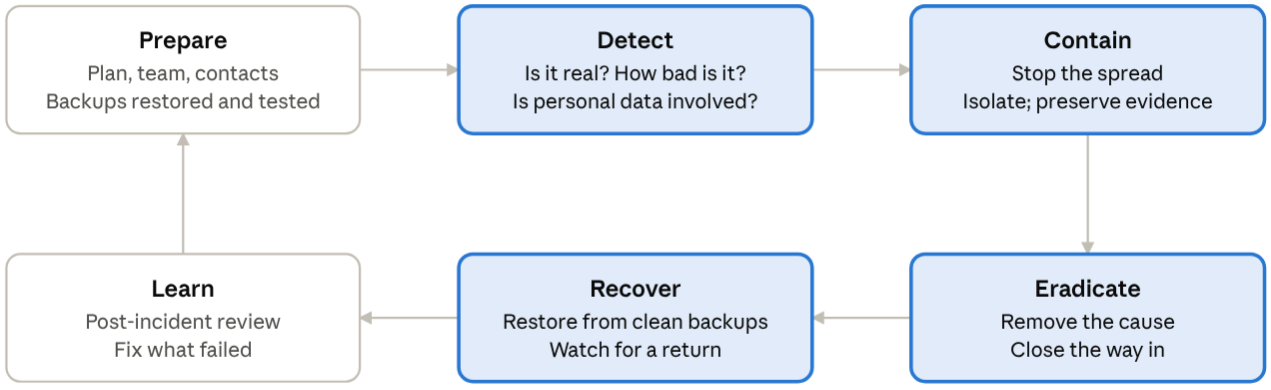
Word	Plain meaning	RSSO example
Event	Anything that can be observed on a system	One failed sign-in; an antivirus pop-up
Incident	An event that harms, or threatens, the confidentiality, integrity or availability of information	A ransom note on the file server; an account used after its owner left
Personal data breach	An incident that affects personal data: it is destroyed, lost, altered, disclosed or accessed without authority	Applicant records copied to an unknown address

The phases

This course uses the syllabus's four phases of the response itself, with preparation before them and lessons learned after.

Phase	The question it answers	At the RSSO
Prepare	Are we ready before anything happens?	A signed plan, a named team, a contact list, backups that have been restored
Detect	Is something wrong, how bad is it, and is personal data involved?	Ben reports a ransom note; Ana confirms what is affected
Contain	How do we stop it spreading, without destroying evidence?	Isolate the server; disable the account that was used
Eradicate	How do we remove the cause?	Remove the attacker's access; install updates; reset passwords
Recover	How do we return to service safely?	Restore from a backup verified clean; watch for the attacker's return
Learn	What do we change so that it does not happen again?	A post-incident review; fix the findings from the Module 4 audit

Four response phases sit between preparing and learning



Shaded: the four phases of the response itself, as the syllabus names them

incident response phases · 6 phases, the 4 response phases shaded

Learning feeds the next round of preparation: each incident should leave the office better prepared than before.

Other frameworks use other words for the same ideas. NIST SP 800-61 Revision 3 (April 2025) places incident response inside the six functions of the NIST Cybersecurity Framework 2.0: Govern, Identify and Protect prepare for incidents; Detect, Respond and

Recover handle them; lessons learned feed improvement. DICT has said it plans a six-stage model under the national cybersecurity plan: Identify, Contain, Analyze, Eradicate, Recover, and Lesson Learned.

What a plan contains

Part	What it says
Purpose, scope and authority	What the plan covers, and who signed it
Severity levels	How bad is bad, and who is called at each level
Roles and contact tree	Names, deputies, numbers, including after hours
One reporting channel	Where anyone reports anything suspicious
Triage checklist	The first questions to answer
Playbooks	Short steps for ransomware, account compromise, data leak, website defacement and a lost device
Evidence handling	What to keep, how, and who keeps it
Communications	Staff, media and data subjects: who speaks, and what is said
Legal and regulatory triggers	The NPC, DICT and law enforcement: when and how
Continuity and recovery	Manual workarounds, and the order in which systems return
Post-incident review	When it happens, who attends, what changes

A simple severity scale for an office like the RSSO (a course model, not a standard):

Level	Meaning	Who is called
Low	One user or device; no personal data at risk	The IT officer
High	Several systems, or personal data may be involved	The response team, including the DPO
Critical	A core service is down, or the sensitive personal data of many people may be exposed	The whole team; the head of office decides at once

What the NPC requires of the plan

NPC Circular 16-03 asks every personal information controller to be ready before a breach:

- A **Data Breach Response Team**, with at least one member who has the authority to make immediate decisions (Section 5). Lesson 5.1.1 covers it.
- A policy and procedures that cover discovery, reporting lines, a preliminary assessment, securing evidence, containment, contacting law enforcement, investigation, notification and mitigation (Section 8).
- Prevention and security measures, such as backups, access control and secure logs, and encryption (Sections 6 and 7).
- **Documentation** of every incident: what happened, its root cause, how it was discovered, the team's actions and decisions, the outcome, and proof of notification; then a post-breach review (Section 9).
- A review of the policy at least once a year by the DPO or a designee (Section 10).

Containment and evidence habits

1. **Isolate first, power off last.** Disconnect affected computers from the network. Switch them off only if they cannot be disconnected, because powering down can destroy evidence held in memory (CISA).
2. **Preserve before you wipe.** Before anything is cleaned, IT or the responders copy the logs and take images of a sample of affected systems (CISA).
3. **Log it.** Every action and decision goes into one incident log: who, what, when, and why.
4. **Talk on a separate channel.** Use phones or meet in person until IT confirms that the attacker cannot read office email.
5. **Restore only from backups verified clean.** A backup taken after the attacker got in may bring the attacker back.
6. **Keep a chain of custody.** For every copy or device kept as evidence: what it is, who collected it, when, where it is kept, and who has handled it since.

The ransom question

- The FBI does not support paying a ransom: paying does not guarantee that you get any data back, and it encourages more attacks.
- Paying does not end the duty to notify: the data has already been taken.
- The decision belongs to the head of office, with legal advice and law enforcement involved. Record the decision and the reasons in the incident log.
- In the 2023 ransomware case from Module 1, the office said it would not pay.

At your desk, in the server room

At your desk	In the server room
Report anything strange at once, through the one channel	A signed plan, a contact tree and short playbooks
Do not switch off, wipe or "clean up"; disconnect from the network only when IT tells you	Isolate, preserve, then eradicate; image before you wipe
Write down what you saw and when	One incident log; restore only from clean backups

Try it 5.1: The first hour, in order (Apply, pairs, 3 minutes)

Ben has just reported a ransom note on the file server. Put these actions in a safe order, and cross out any that do not belong in the first hour.

1. Restore the server from last night's backup.
2. Disconnect the affected server from the network.
3. Open the incident log and write down what Ben saw and when.
4. Tell the DPO that applicant data may be involved.
5. Wipe the infected computers to stop the spread.
6. Copy the logs and take images of affected systems before anything is changed.
7. Declare the incident and its severity.
8. Post on the office's page that everything is fine.

Check yourself 5.1

1. Name the six phases this course uses, in order.
2. Why isolate a computer before you power it off?
3. Name three things NPC Circular 16-03 says an office must have ready for a breach.
4. Does paying a ransom end the duty to notify? Why?

Lesson 5.1.1: Roles and responsibilities

Key idea: every phase needs a named person for every job, decided before the incident, with a deputy for each.

Roles by phase

Role	Detect	Contain	Eradicate	Recover
Incident commander	Declares the incident and its severity	Approves isolation steps	Approves the clean-up plan	Approves the return to service
Technical lead	Confirms the signs; finds which systems are affected	Isolates systems, disables accounts, preserves evidence	Removes the attacker's access; installs updates; resets passwords	Restores from verified backups; watches for a return
DPO or privacy lead	Checks whether personal data is involved	Starts the breach assessment; records when the clock started	Confirms which data, and how many people	Files the NPC notification; notifies data subjects; documents
Communications lead	Keeps staff informed through one channel	Issues internal notices and a holding statement	Updates staff and partners	Drafts the public message
Scribe	Opens the incident log	Records every decision with its time	Keeps the timeline current	Drafts the final report
Legal or head-of-office liaison	Advises on reporting duties	Contacts law enforcement and DICT as needed	Clears external statements	Signs off the report and the lessons learned

At the RSSO

Role	Usually	Why
Incident commander	Director Eva	She can make immediate decisions for the office
Technical lead	Ana	She runs the systems; a vendor helps only under a written agreement

Role	Usually	Why
DPO or privacy lead	Carla	She decides on notification and files it
Communications lead	A staff member named by the head	One voice for staff, media and applicants
Scribe	Ben	Careful records are his daily work
Legal or head-of-office liaison	Named by the head; Carla advises	Links to the central office, law enforcement and DICT

In a small office one person may hold two roles. Name a deputy for every role, so that the plan still works when someone is on leave or cannot be reached on a Friday night.

The Data Breach Response Team

NPC Circular 16-03, Section 5, asks for a team that is ready before any breach:

- At least one member has the **authority to make immediate decisions** on critical action.
- The DPO may be a member. If not, the team reports to the DPO in writing.
- The office may outsource parts of the response, but it keeps its obligations.

One channel, one log, one voice

- **One channel:** everyone knows where to report anything suspicious.
- **One log:** the scribe records every event, decision and action, each with its time.
- **One voice:** only the communications lead speaks outside the team. A holding statement says what is known, what is being done and when the next update will come, without guessing or denying.

Try it 5.1.1: Who does it? (Apply, 2 minutes in class)

Name the role for each task.

1. Decides that the incident is Critical.
2. Disables the account that the attacker used.
3. Writes "5:30 PM: large outbound transfer seen; Ana isolating the server".
4. Checks whether the copied files hold ID numbers and health information.
5. Answers a reporter's call with a holding statement.
6. Reports the crime to the NBI or the PNP Anti-Cybercrime Group.
7. Files the notification through the NPC's DBNMS.
8. Approves the portal's return to service.

Check yourself 5.1.1

1. Which role declares the incident?
2. What must at least one member of the Data Breach Response Team be able to do?
3. Who speaks to the media?
4. Why name a deputy for every role?

When personal data is involved

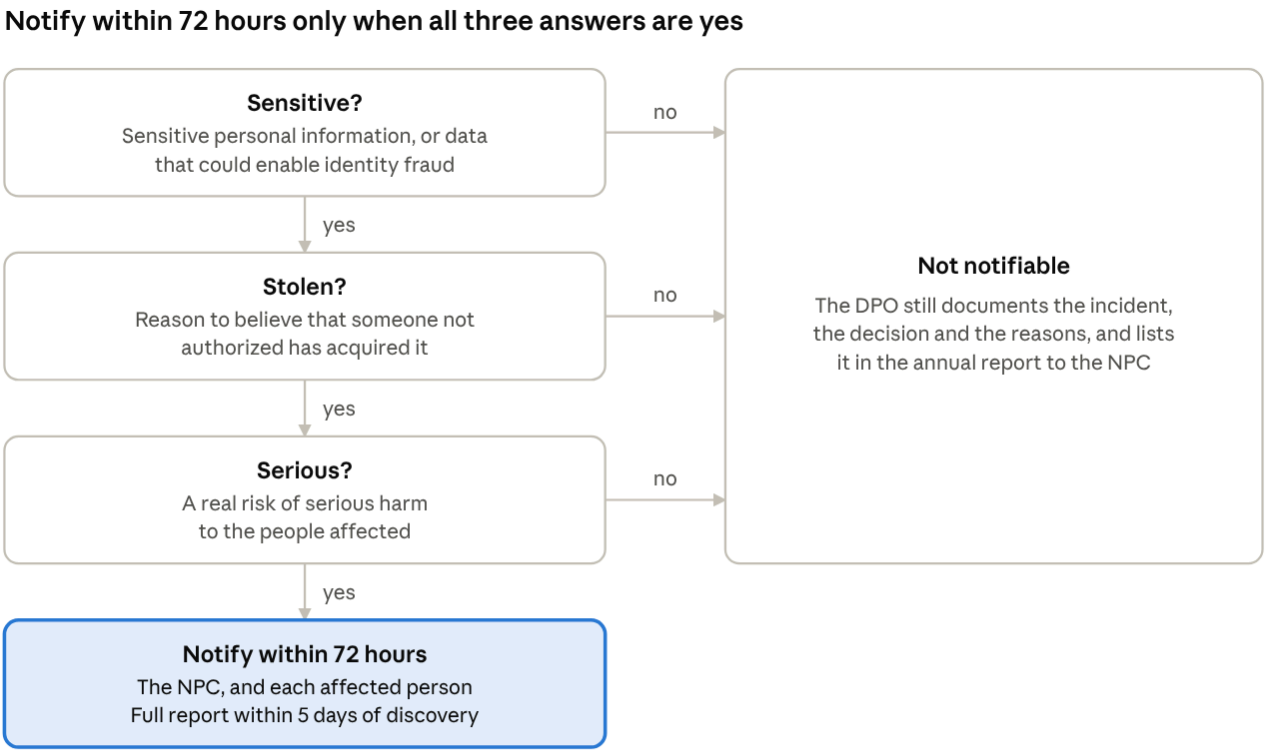
Key idea: you call the fire department when you smell smoke, not when you see ashes. The clock starts at reasonable belief, not at certainty.

Must we notify? The 3S test

From Module 1: notify the NPC and the affected people when all three are true (NPC Circular 16-03, Section 11).

- **Sensitive:** sensitive personal information, or information that could enable identity fraud.
- **Stolen:** there is reason to believe that someone not authorized has acquired it.
- **Serious:** the acquisition is likely to give rise to a real risk of serious harm to the people affected.

When unsure, weigh the likelihood of harm first. Also weigh whether 100 or more people are involved, public safety or national security, information that the law requires to be kept confidential, and vulnerable groups (Section 13).



NPC notification decision · 3 questions, 2 outcomes

A single no means the NPC need not be notified, but the decision is still documented. Three yeses start the 72-hour duty.

The 72-5 rule

Step	Rule	Source
Notify the NPC	Within 72 hours of knowing, or reasonably believing, that a breach needing notification has happened	Circular 16-03, Sec 17
Notify each affected person	Within 72 hours, individually, through secure means	Sec 18
Delay	Only as long as needed to find the scope, stop further disclosure or restore the system; never to hide the breach	Sec 17

Step	Rule	Source
No delay allowed	When 100 or more people are affected, or disclosing the sensitive information would harm them: notify within 72 hours on what you know	Sec 17
Full report	Within 5 days from discovery, even while a request to the NPC is pending	Sec 17; NPC Advisory 2026-02

Certainty is not required. Notify on the information you have, and send more as you learn it.

What the notices must say

To the NPC (Section 17):

- **The nature of the breach:** how it happened and the weakness that allowed it; a timeline; the approximate number of people or records; the kind of breach; its likely consequences; the DPO's contact details.
- **The personal data possibly involved:** the sensitive personal information, and any information that could enable identity fraud.
- **The measures taken or planned:** to address the breach, secure or recover the data, reduce harm, inform the people affected (or the reasons for any delay), and prevent a repeat.

To each affected person (Section 18):

- What happened, and which of their personal data may be involved.
- What the office has done to address the breach and to reduce harm.
- Whom to contact for more information, and any help the office offers.

The notice goes to each person individually, by secure written or electronic means. Verify the recipient, and do not disclose more personal data in the notice itself. If individual notice is impossible, or would take disproportionate effort, ask the NPC to approve another way, such as a public announcement. The information may be given in phases.

Requests to the NPC

- An exemption from notifying data subjects, a postponement, or the use of alternative means must be **requested and justified**.
- An exemption cannot be combined with a postponement or with alternative means.
- Approval must be express and in writing: **silence is not approval** (NPC Advisory 2026-02).

- A pending request does not stop the clock on the full report.

How and where

- File breach notifications through the NPC's **DBNMS** (dbnms.privacy.gov.ph), the only channel for breach notifications and annual security incident reports since April 2022.
- Send the full breach report within 5 days from discovery to admindbnms@privacy.gov.ph, with the subject line FBR_NameofPIC_NameofDPO (Advisory 2026-02).
- Document every incident, including those that need no notification, and include them in the annual summary to the NPC (Section 22).
- Hiding a breach is a crime. Concealing a security breach involving sensitive personal information, after knowing of it and of the duty to notify, is punished under the Data Privacy Act, Section 30.

Other reports

Report to	When	Note
DICT	A cybersecurity incident at a government office	Through the mechanism in DICT Department Circular 005, series of 2024, on reporting and mandatory disclosure of cybersecurity incidents. Read its text for any deadline before you rely on one
The NBI or the PNP Anti-Cybercrime Group	A crime may have been committed, such as illegal access or extortion	They enforce the Cybercrime Prevention Act (RA 10175, Section 10)
The central office and partners	As your plan sets out	Use one voice and agreed words

Citizens report scams to hotline 1326 and the CICC's ScamSafe. An office's own incident follows the routes above.

Try it 5.2: Must we notify? (Evaluate, pairs, 3 minutes in class for cases 1 and 4; cases 2 and 3 after today)

For each case: notify or not, when did the clock start, and what is the deadline?

1. On Monday at 9:00 AM, Ana sees that a supervisor's account signed in from abroad at 2:00 AM and exported 900 applicant records, with ID numbers. The supervisor was asleep.
2. A partner office emails to say it received, by mistake, a file with 40 applicants' medical certificates. It has not deleted it yet and asks what to do.
3. The company that stores the portal's backup reports that a backup file with all 48,000 records could be downloaded without a password for three weeks. Its logs show two downloads from unknown addresses.
4. The SMS vendor reports a breach of its own system: the names and mobile numbers of RSSO applicants were taken. No ID numbers were stored there.

Check yourself 5.2

1. What are the 3S?
2. When does the 72-hour clock start?
3. Name four things the notice to each affected person must contain.
4. The NPC has not answered your postponement request. May you postpone?

The capstone tabletop exercise (40%)

Your team becomes the RSSO's response team. The facilitators form the **white cell**: they deliver new information, called **injects**, as the fictional clock moves, and they play everyone outside your team, from the head of office to a reporter. Eighty minutes cover about three days.

Item	Detail
Time	9:05 briefing; 9:20 to 10:40 three rounds; 10:50 to 11:15 final report; 11:15 report-outs
Team	Your Day 1 team. Roles are drawn by lot; anyone who led an earlier activity takes a different role. Teams of five combine the scribe and the communications lead
Materials	The Module 5 Tabletop Kit: the RSSO fact sheet, role cards, the incident log, and the templates for the immediate response plan and the final report

Item	Detail
Submit	The immediate response plan at the end of Round 1; the incident log and the final report through the submission link by 11:15 AM. If connectivity fails, the grace period runs until 5:00 PM the same day

The rounds

Round	Fictional time	Minutes	Your team decides
1. Detect	Friday, 4:45 PM to 9:00 PM	25	Declare the incident and its severity; whom to call; the first containment step; whether personal data is involved; when the 72-hour clock starts
2. Contain and eradicate	Saturday	30	What to isolate; how to keep evidence; the eradication plan; a holding statement; whether the clock has already started
3. Notify and recover	Sunday to Monday	25	Notices to the NPC and to the people affected: what, when, how; any request to the NPC; reports to DICT and law enforcement; the ransom stance; the restore order; lessons learned

Rules

- Log every decision with its fictional time and a reason. A decision without a reason earns no credit.
- Ask the white cell anything you would ask in real life; it answers in character.
- Nothing real is named: no real offices, people or systems.
- Stay in your role. The incident commander has the final word, and the scribe records any disagreement.

What your team submits

1. An **immediate response plan**, one page, at the end of Round 1.
2. The **incident log**, kept from the first minute to the last.

3. The **final incident report**, with the fields of the NPC notification and the notice to the people affected.

How it is scored (100 points, scaled to 40%)

Criterion	Points	Full marks means
Legal protocols and DPA notification	40	A correct breach decision; a defensible clock start; complete content for the NPC and for the people affected; requests handled properly; DBNMS filing and documentation; other reports identified
Logic of containment	30	A sensible order and scope; evidence preserved; eradication and recovery justified
Final incident report	30	Accurate and complete, with a clear timeline, a preliminary root cause, and lessons learned with owners
Participation check	Gate	Every member held a role and contributed; exceptions are flagged to ILCDB, not scored

Tips for your team

- Start the log in the first minute, and name the scribe before anything else.
- Ask "is personal data involved?" in Round 1, not in Round 3.
- Smoke, not ashes: the clock can start before you are sure.
- Use your desk card: isolate first, preserve before you wipe, one voice.
- Your Module 4 findings register may already hold the root cause.

Course close

Five modules, one office

Module	What you can now do for your office
1	Name the threats; apply the Data Privacy Act, ISO/IEC 27001 and the ASEAN AI guide
2	Find weak spots, model threats, rate risks, and spot social engineering

Module	What you can now do for your office
3	Choose controls: zones, encryption, MFA and roles
4	Keep devices and tools safe, use threat intelligence, and audit an office's records
5	Respond, notify, recover and report

Your 30-day office plan (Create, 5 minutes)

Write three lines for your own office. Make each one checkable.

When	Action	Owner	Done when
This week			
Within two weeks			
Within 30 days			

Ideas: ask your ICT head to subscribe to the National CERT's advisories; test the incident reporting path (does everyone know the one channel?); restore-test one backup; name your Data Breach Response Team, with a deputy for each role; hold a 30-minute awareness session; run a 60-minute tabletop with your unit.

Take-home toolkit

Need	Where to go	Watch out for
Report a scam	Hotline 1326 and the CICC's ScamSafe	These take reports from the public; an office's own incident follows its plan
Check a suspicious message	ScamCheck.ph, as a second opinion	Remove names, account numbers, passwords and one-time codes first; never for official records
Check a password	Pwned Passwords	Invented passwords only; for real ones, use a password manager's own breach check
Check an image	Content Credentials Verify	A file without credentials is not proven fake

Need	Where to go	Watch out for
Run an exercise	CISA Tabletop Exercise Packages: templates with objectives, scenarios, discussion questions, a slide deck, a feedback form and an after-action report	Written for the US: swap its laws and channels for the DPA, the NPC and DICT
Know the breach duties	The NPC's DBNMS; DICT, through the channel in its Department Circular 005	Read Circular 005 itself before relying on its deadlines
Know your exposure	Ask the National CERT, through your ICT head, how its breach monitoring covers your office's domain	
Judge any other tool	The five questions from Lesson 4.2	Approved tools only for office data

Desk card: Module 5 additions

Add these to your desk card from Modules 1 to 4.

Phrase	What it means	What you do
Prepare, detect, contain, eradicate, recover, learn	The phases of incident response	Know your role in each one before anything happens
Isolate first, power off last	Containment that keeps the evidence	Disconnect from the network; switch off only if you cannot disconnect
Preserve before you wipe	Evidence before repair	Copy logs and systems before any clean-up
Smoke, not ashes: 72-5	The clock starts at reasonable belief; 72 hours to notify, 5 days for the full report	Tell the DPO at once; notify on what you know
Silence is not approval	Requests to the NPC need written approval	Never assume a postponement was granted

Phrase	What it means	What you do
One channel, one log, one voice	Incident discipline	Report in one place, log everything, let one person speak

Glossary

Term	Plain meaning
After-action report	A written review of an exercise or incident: what happened, what worked, what to change
Chain of custody	A record of who collected each piece of evidence, when, where it is kept, and who has handled it since
Containment	Stopping an incident from spreading
Data Breach Response Team	The team that handles personal data breaches, with at least one member who can make immediate decisions
DBNMS	The NPC's online system for breach notifications and annual incident reports
Eradication	Removing the cause of an incident, such as malware or the attacker's access
Event	Anything that can be observed on a system
Exemption, postponement	Requests to the NPC not to notify data subjects, or to notify them later; both need written approval
Hot wash	A short discussion right after an exercise: what went well, what to change
Holding statement	A short public message that says what is known, what is being done, and when the next update will come
Image (of a system)	An exact copy of a computer's storage or memory, kept as evidence
Incident	An event that harms or threatens the confidentiality, integrity or availability of information

Term	Plain meaning
Incident commander	The person who declares the incident and makes the final decisions in the response
Incident log	The single record of every event, decision and action, each with its time
Inject	New information given to teams during a tabletop exercise
Personal data breach	An incident in which personal data is destroyed, lost, altered, disclosed or accessed without authority
Ransomware	Malware that locks files and demands payment; many attackers also copy data and threaten to publish it
Recovery	Returning systems to service safely
Scribe	The team member who keeps the incident log
Tabletop exercise	A discussion-based rehearsal of an incident, with no real systems touched
White cell	The facilitators who run a tabletop exercise and play everyone outside the team

Answers

Try it 5.1: The first hour, in order

A safe order: **7** (declare the incident and its severity) and **3** (open the log) together; then **2** (disconnect the server); **6** (preserve the logs and images); **4** (tell the DPO). Accept any order that logs from the start, isolates before restoring, preserves before wiping, and tells the DPO within the first hour.

Not in the first hour: **1**, because a restore comes only after eradication, from a backup verified clean; **5**, because wiping before preserving destroys evidence, and clean-up belongs to eradication; **8**, never, because a false statement misleads the public, and hiding a breach of sensitive personal information is a crime under the Data Privacy Act, Section 30. Use a holding statement instead.

Check yourself 5.1

1. Prepare, detect, contain, eradicate, recover, learn.
2. Powering down can destroy evidence held in memory; isolating stops the spread and keeps it.
3. Any three of: a Data Breach Response Team with someone who can decide immediately; procedures from discovery to notification; documentation of every incident and a post-breach review; prevention and security measures such as backups, secure logs and encryption; a yearly review of the policy.
4. No. The data has already been taken, so the duty to notify remains; paying also does not guarantee the data back.

Try it 5.1.1: Who does it?

1. Incident commander.
2. Technical lead.
3. Scribe.
4. DPO or privacy lead.
5. Communications lead.
6. Legal or head-of-office liaison.
7. DPO or privacy lead.
8. Incident commander.

Check yourself 5.1.1

1. The incident commander.
2. Make immediate decisions on critical action.
3. Only the communications lead, using agreed words.
4. So that the plan still works when someone is on leave or cannot be reached.

Try it 5.2: Must we notify?

Case	Decision	Clock and deadline
1	Notify. Sensitive: government ID numbers. Stolen: an export the account's owner did not make. Serious: a real risk of identity fraud. Contain at once: end the account's sessions, reset its password, check MFA	The clock started Monday 9:00 AM, when Ana saw the export. With 100 or more people, no delay is allowed: the NPC and the 900 applicants by Thursday 9:00 AM; the full report within 5 days

Case	Decision	Clock and deadline
2	It depends, and the DPO decides. Health information is sensitive and an unauthorized office has it, but it is a government office willing to delete it. Ask for deletion and written confirmation today. If confirmed and the risk of serious harm is judged low, document it as not notifiable; if not, notify	If notifiable, 72 hours from the partner's email. Either way, record the decision and the reasons
3	Notify. All three tests are met for 48,000 people. The RSSO notifies even though the vendor made the error, because the office stays responsible for data others process for it (RA 10173, Secs 14 and 21(a)). Require the vendor to close the access and keep its logs	72 hours from the vendor's report; no delay allowed
4	The RSSO, as the controller, decides and notifies, not the vendor. Names and mobile numbers are not sensitive personal information, but they can be used for scam texts that impersonate the RSSO. With so many people involved, weigh the harm under Section 13; many DPOs would notify. Either way, warn staff and applicants about fake RSSO texts, document the decision, and check the vendor's agreement	If notifiable, 72 hours from the vendor's report

Check yourself 5.2

1. Sensitive, Stolen, Serious.
2. When the office knows, or reasonably believes, that a breach needing notification has happened.
3. Any four of: what happened; which personal data may be involved; what the office has done to address the breach; what it has done to reduce harm; whom to contact; any help offered.
4. No. Approval must be express and in writing; silence is not approval.

Sources

All sources were opened and checked between 19 and 20 October 2026. Every person, office, address and record in the scenario is fictional.

- NPC Circular 16-03, Personal Data Breach Management, Sections 5 to 11, 13, 17, 18 and 22: NPC
- NPC Advisory 2026-02 (11 May 2026), breach notification through the DBNMS: NPC
- The DBNMS: NPC
- Data Privacy Act of 2012 (RA 10173), Sections 14, 21 and 30: BATASnatin
- Cybercrime Prevention Act (RA 10175), Section 10, law enforcement authorities: BATASnatin
- NIST SP 800-61 Revision 3 (April 2025): NIST
- DICT's planned six-stage incident model and intelligence fusion center: GMA, 28 August 2024
- DICT Department Circular 005, series of 2024 (title only; its text was not available to this course): National Administrative Register
- Ransomware first steps: isolate, power down only if you cannot disconnect, take images: CISA
- The FBI on paying a ransom: FBI
- CISA Tabletop Exercise Packages: CISA
- Hotline 1326: PNA; ScamSafe: Newsbytes
- ScamCheck.ph: World Ngayon
- Pwned Passwords: Troy Hunt; National CERT monitoring: Troy Hunt
- Content Credentials: Content Authenticity Initiative FAQ